

The Rules: UK Law and the Regulatory Landscape

WHY THIS MODULE MATTERS

There is no single UK AI Act, and that leads people to assume AI is unregulated. It is not. This module covers the law that already applies in full — chiefly data protection and equality law — and how the UK approach differs from the EU and US.

5.1 The UK Approach

The United Kingdom has deliberately not passed a single horizontal AI statute. Instead, existing regulators apply cross-sectoral principles to AI within the remits they already hold. The practical consequence is that AI is regulated in the UK by the law that applies to what the AI is doing.

The policy approach, set out by the Department for Science, Innovation and Technology, rests on five principles that regulators are expected to apply: safety and security; transparency and explainability; fairness; accountability and governance; and contestability and redress. These are not directly enforceable in themselves — they shape how existing regulators use existing powers.

- The **Information Commissioner’s Office (ICO)** — data protection, by far the most frequently engaged regulator for AI.
- The **Equality and Human Rights Commission** — discriminatory outcomes under the Equality Act 2010.
- The **Financial Conduct Authority** — AI used in financial services, including consumer outcomes under the Consumer Duty.
- The **Competition and Markets Authority** — consumer protection, misleading claims and competition effects.
- **Ofcom** — online safety and content moderation systems.
- **Sector regulators** — the MHRA, CQC, Ofsted and others, within their existing fields.

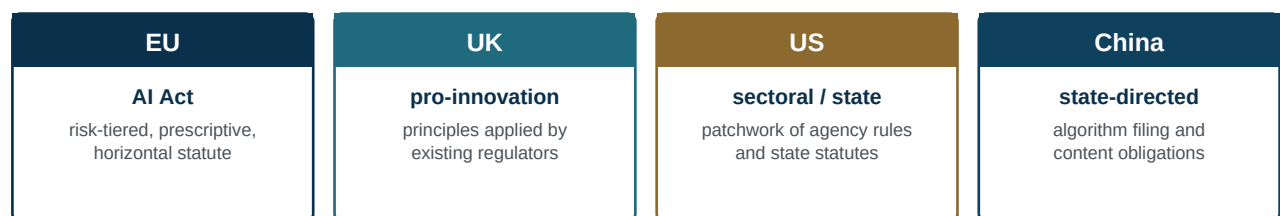


Figure 5.1 — Four regulatory philosophies applied to the same technology.

For comparison: the EU AI Act takes the opposite approach, classifying systems by risk tier and imposing obligations directly, with prohibited practices at the top. It reaches UK organisations that place systems on the EU market or whose outputs are used in the EU. The United States has relied largely on sectoral enforcement and state-level legislation. Several Gulf states have pursued national AI strategies with lighter statutory constraints. If your organisation operates only in the UK, UK data protection and equality law is where your obligations begin.

5.2 UK GDPR: The Seven Principles

The UK GDPR — the retained EU regulation as it forms part of UK law, read with the Data Protection Act 2018 and the amendments made by the Data (Use and Access) Act 2025 — applies whenever personal data is processed. Training a model on personal data is processing. So is using a model to produce an output about an identifiable person.

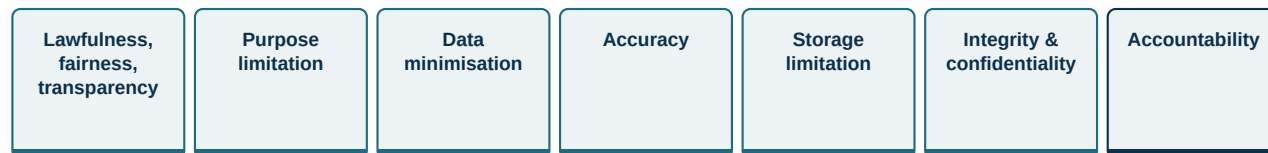
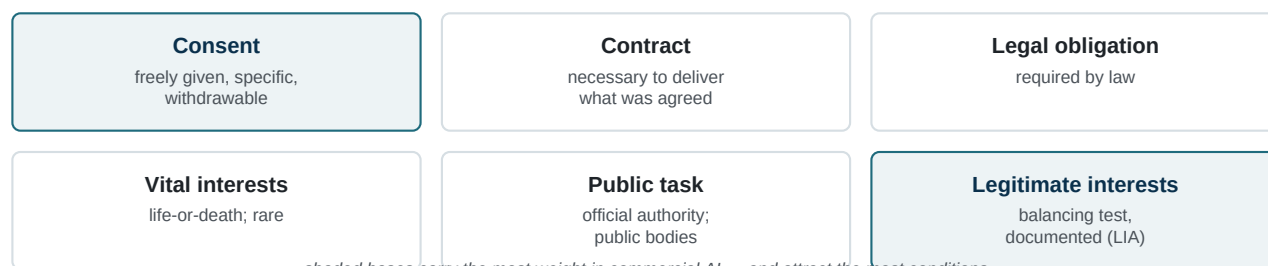


Figure 5.2 — The seven Article 5 principles.

Three of these cause most of the difficulty in AI projects. **Purpose limitation** means data collected for one purpose cannot simply be reused to train a model for another; this is the single most common compliance failure in AI development. **Data minimisation** sits in direct tension with the engineering instinct to retain everything in case it proves predictive. **Accuracy** applies to the outputs a system produces about a person, not merely to the input records — an inferred score is personal data and must not be wrong.

5.3 Lawful Basis

Every processing activity needs one of six lawful bases, chosen before processing begins and documented. You cannot switch basis later because the first one became inconvenient.



shaded bases carry the most weight in commercial AI — and attract the most conditions

Figure 5.3 — The six lawful bases under Article 6.

For most commercial AI, the realistic candidates are legitimate interests, contract, or consent. Legitimate interests requires a documented balancing test weighing your interest against the rights of the people affected — and it is available only where those people would reasonably expect the processing. Consent must be freely given, specific and withdrawable, which makes it a poor fit for training data, since a model cannot readily unlearn one person's contribution. Special category data — health, ethnicity, religion, biometrics, sexual orientation, trade union membership — needs an additional Article 9 condition on top.

5.4 Automated Decision-Making and Individual Rights

Article 22 addresses decisions made about a person solely by automated means where the effect is legal or similarly significant — refusing credit, rejecting a job application, terminating an account. Such decisions are restricted, and where permitted the person must be told, must be able to obtain human intervention, express their point of view and contest the outcome. The Data (Use and Access) Act 2025 reformed the detail of this regime, but the safeguards for significant decisions remain.

Note the word "solely". Organisations frequently claim a human is in the loop when the human simply approves the system's output without the ability or information to reach a different one. That is not meaningful human involvement, and calling it so does not remove the Article 22 obligations.

Separately, individuals hold rights that apply to AI systems like any other processing: access to their data, rectification of inaccuracy, erasure in defined circumstances, objection to processing based on legitimate interests, and portability. A subject access request that touches an AI system will require you to explain what data it holds and, in the case of significant automated decisions, meaningful information about the logic involved.

5.5 Data Protection Impact Assessments

A DPIA is legally required where processing is likely to result in a high risk to individuals — which covers most AI making decisions about people, any systematic evaluation or profiling, large-scale special category processing and biometric identification. It must be completed before processing begins, not written up afterwards to document a decision already taken.



Figure 5.4 — The core stages of a Data Protection Impact Assessment.

In practice the DPIA is the most useful governance artefact available, because it forces a project to state in writing what the system does, why less intrusive means will not work, who could be harmed and what mitigations exist. Projects frequently change shape during a DPIA. That is the mechanism functioning correctly, not an obstruction.

CASE STUDY — CLEARVIEW AI AND THE LIMITS OF PUBLIC DATA

Clearview AI built a facial recognition database by scraping billions of images from public websites and social media, then sold search access against that database.

In 2022 the ICO issued an enforcement notice and a fine exceeding £7.5m, ordering deletion of UK residents' data. Several European authorities reached similar conclusions, and the enforcement history has continued to develop since.

The principle established is the one most often misunderstood in AI development: data being publicly accessible does not make it free to process. The people photographed had no expectation their images would be used to build a biometric identification product, no lawful basis covered it, and biometric data is special category data requiring an additional condition.

The lesson generalises well beyond facial recognition. "We scraped it from the open web" is not a lawful basis, and it is a common assumption inside AI teams.

KEY TAKEAWAYS

- The UK has no single AI statute; AI is regulated through existing law applied by existing regulators, principally the ICO.
- UK GDPR applies in full to training data and to outputs about identifiable people. Purpose limitation is the most commonly breached principle in AI work.
- A lawful basis must be chosen and documented before processing starts; consent is a poor fit for training data because models cannot readily unlearn.
- Article 22 restricts solely automated decisions with significant effects — and a human who cannot realistically reach a different conclusion does not make a decision non-automated.
- A DPIA is mandatory for high-risk processing, must come before deployment, and is the most useful governance document most projects will produce.
- Public availability of data is not a lawful basis for processing it.

FURTHER READING

- ICO — Guidance on AI and data protection, and the AI and data protection risk toolkit
- ICO — Data Protection Impact Assessments guidance, ico.org.uk
- ICO — enforcement action against Clearview AI Inc (2022)

CHECK-IN QUIZ

1. A retailer proposes reusing CCTV footage, captured for security, to train a model that analyses shopper behaviour. The principle most directly engaged is:

CHECK-IN QUIZ

- A. Accuracy
- B. Storage limitation
- C. Integrity and confidentiality
- D. Purpose limitation

2. A team selects legitimate interests as its lawful basis. To rely on it, the team must:

- A. Obtain consent as well, for completeness
- B. Document a balancing test and be satisfied the processing is within people's reasonable expectations
- C. Register the processing with the ICO in advance
- D. Demonstrate that no alternative basis exists

3. A wellbeing app infers likely stress levels from usage patterns and stores the inference against each employee. The inferred data is:

- A. Not personal data, because it is derived rather than collected
- B. Exempt, because the employee installed the app voluntarily
- C. Personal data, and likely special category data requiring an Article 9 condition
- D. Outside UK GDPR because no diagnosis is made

4. A project team plans to complete its DPIA in the fortnight after launch, so it can describe the system as built. This is:

- A. Non-compliant — a DPIA must be completed before high-risk processing begins
- B. Efficient, since the description will be more accurate
- C. Acceptable if the ICO is notified
- D. Acceptable for systems bought from a vendor

5. An individual makes a subject access request relating to an automated decision that significantly affected them. Alongside their data, they are entitled to:

- A. The model's source code
- B. The names of the staff who built the system
- C. Meaningful information about the logic involved in the decision
- D. A copy of the full training dataset